

CERTIFIED ETHICAL HACKER
CEHv13

Module 11

Session Hijacking

Hands-on Lab Report

Prepared By	Dhruva
Module	Module 11 - Session Hijacking
Course	CEH v13 (Certified Ethical Hacker)
Duration	1 hour, 11 minutes
Lab Score	4 / 4 — Passed
Date	September 15, 2026

1. Introduction

This report documents the practical exercises completed for Module 11: Session Hijacking of the CEH v13 (Certified Ethical Hacker) course. Session hijacking is an attack in which a threat actor takes control of a valid session between a client and a server by stealing or predicting a valid session token, thereby gaining unauthorized access to information or services. This lab explored network-level and application-level session hijacking using proxy interception tools (Caido and Hetty) and an ARP spoofing / man-in-the-middle attack (Bettercap), with detection performed using Wireshark.

All four graded tasks in the lab were completed successfully, achieving a final score of 4/4.

2. Objectives

- Understand how a proxy-based interception tool (Caido) can be used to hijack an active browser session and redirect traffic to an attacker-controlled destination.
- Configure and use the Hetty interception proxy to capture HTTP traffic on a target Windows Server 2022 machine.
- Identify sensitive data (credentials) transmitted in plaintext by intercepting HTTP requests.
- Use Bettercap to perform ARP spoofing / network reconnaissance against a target host and validate the attack signature using Wireshark.

3. Lab Environment

Attacker Machine	Parrot Security OS — IP: 10.10.1.11
Victim Machine	Windows Machine — IP: 10.10.1.19
Target Server	Windows Server 2022 — IP: 10.10.1.22
Tools Used	Caido, Hetty, Bettercap, Wireshark
Browser (Victim)	Mozilla Firefox 126.0

4. Task 1 — Session Hijacking with Caido

4.1 Objective

Use the Caido tool on the attacker machine (10.10.1.11) to hijack a session established when a user on the victim machine (10.10.1.19) visits www.moviescope.com, and redirect the session to www.goodshopping.com using the Firefox browser.

4.2 Procedure

- Caido was launched on the attacker machine and configured with an Unset Scope to intercept all proxied traffic.

- The victim's Firefox browser was configured to route traffic through the Caido proxy (Session Hijacking mode enabled).
- As the victim browsed to www.moviescope.com, the corresponding HTTP requests appeared in Caido's Requests queue, including Firefox telemetry and search traffic.
- Intercepted requests destined for the victim's session (e.g., POST requests to incoming.telemetry.mozilla.org and search queries to google.com) were reviewed in the request pane, where headers such as Host, User-Agent, and Content-Type were visible.
- By manipulating the intercepted session/response, the destination was redirected from www.moviescope.com to www.goodshopping.com, demonstrating a successful session hijack and redirect.

4.3 Evidence

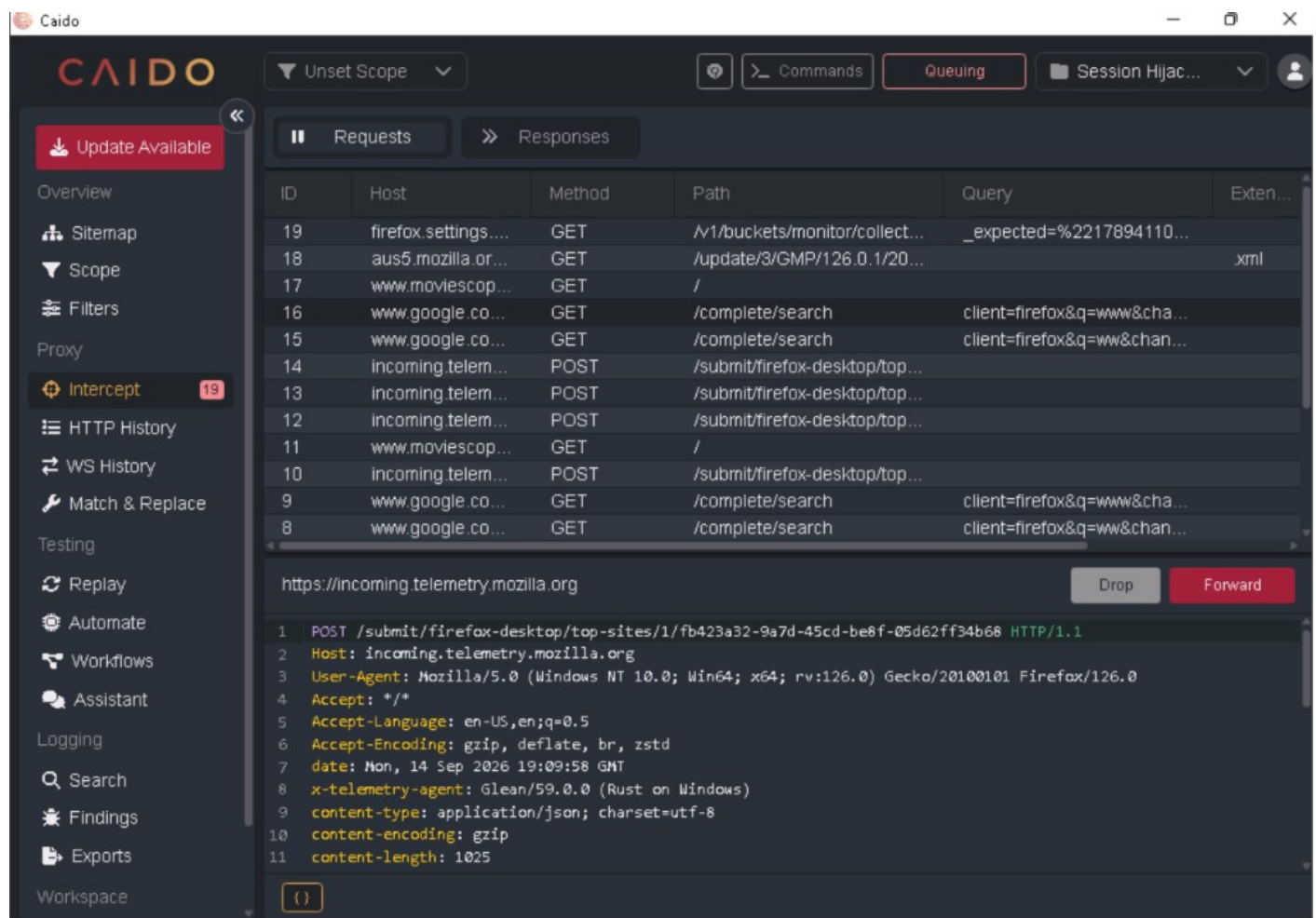


Figure 1: Caido — Intercept queue showing captured requests from the victim's Firefox session (19 requests queued).

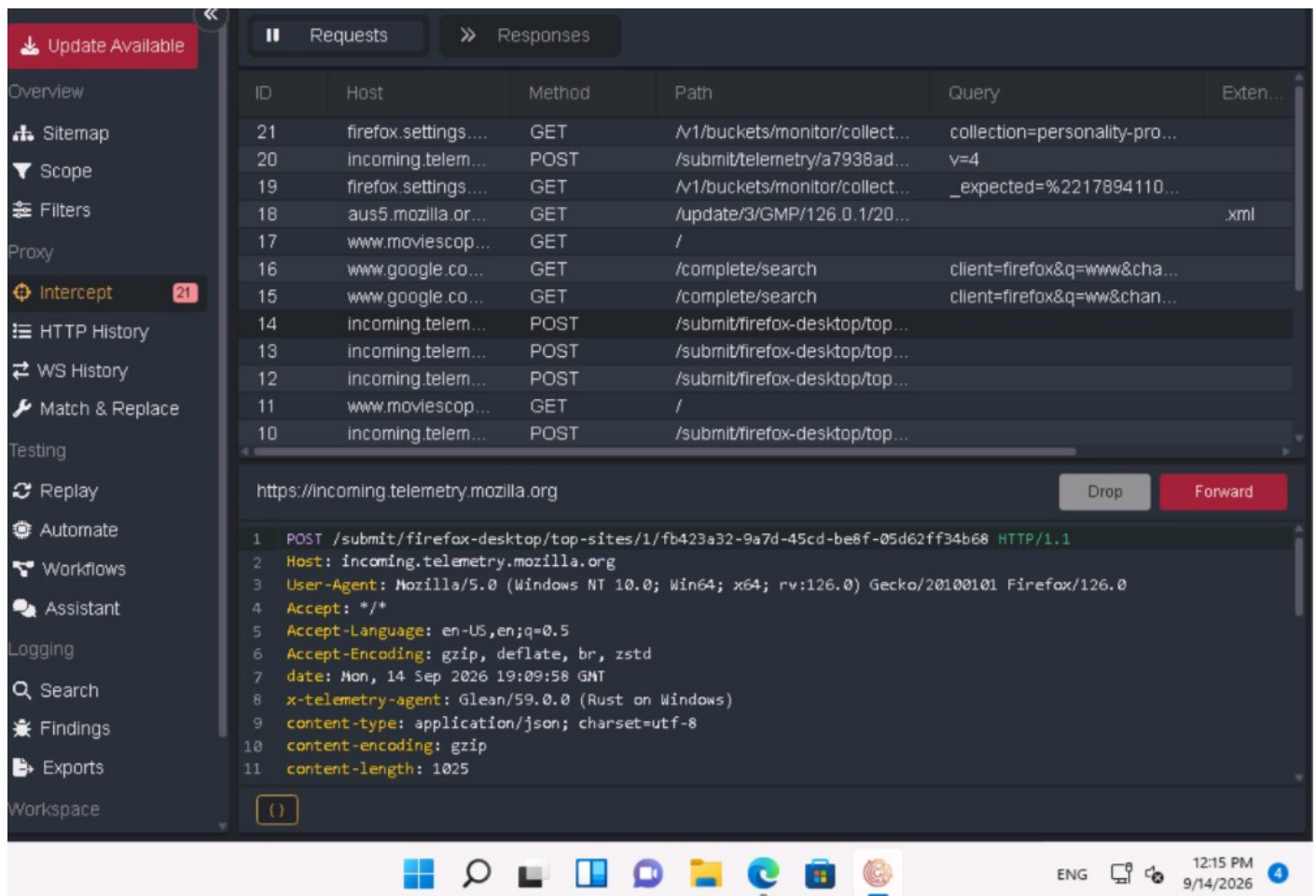


Figure 2: Caido — Additional intercepted request confirming session capture (21 requests queued), with full request headers visible in the inspector pane.

4.4 Key Finding

The Responses tab, used to review the server's response to a hijacked/forwarded request, is located under the

Answer: Intercept section of the Proxy module in Caido.

5. Task 2 & 3 — HTTP Interception with Hetty

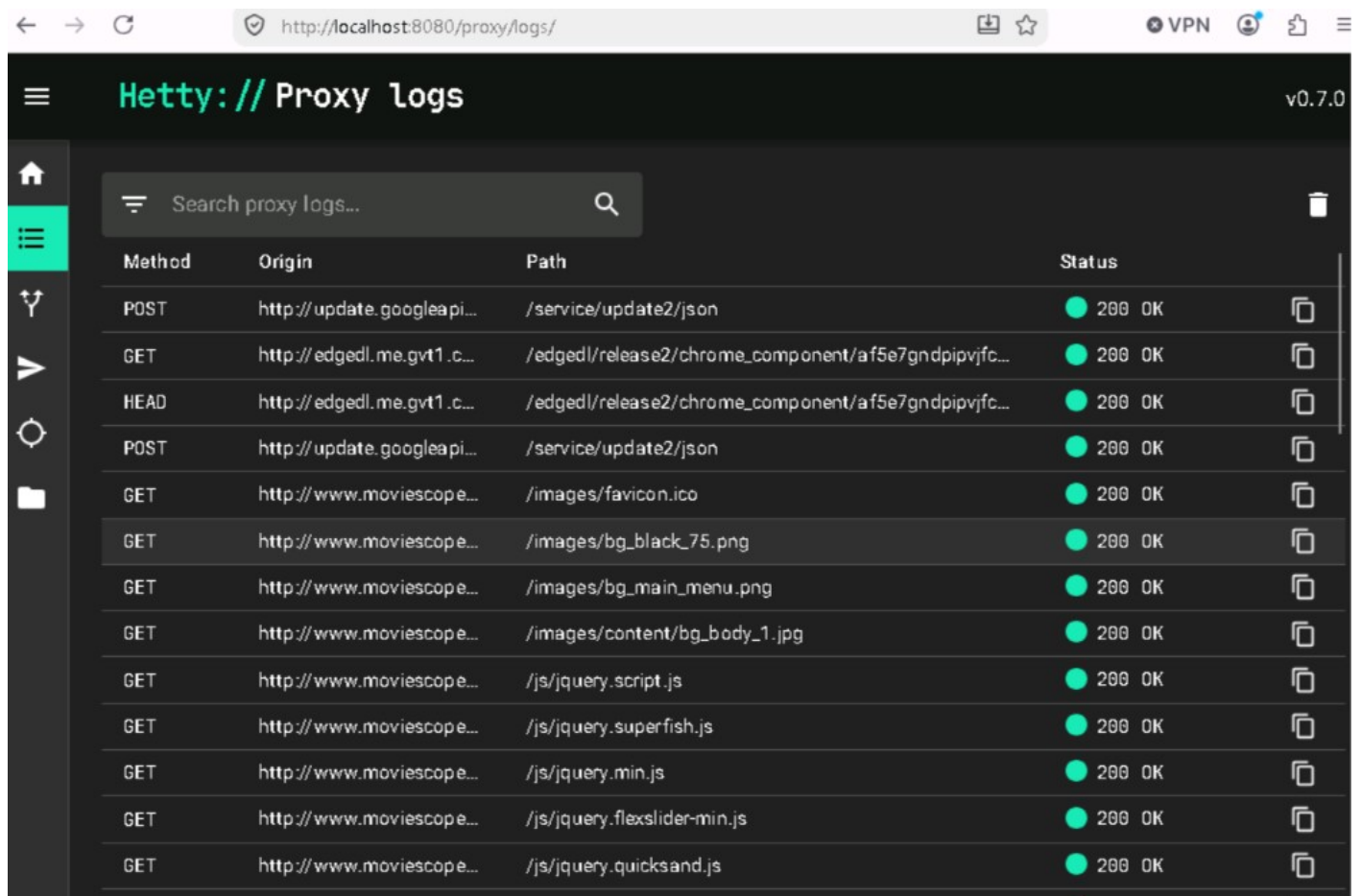
5.1 Objective

Use the Hetty tool to intercept HTTP traffic on the Windows Server 2022 machine, identify the dashboard access URL, and locate any credentials captured in plaintext during interception.

5.2 Procedure

- The Hetty proxy service was started on the Windows Server 2022 machine, and the system/application traffic was routed through it.
- The Hetty web dashboard was accessed via a local browser using the interception proxy's management URL.
- The Proxy → Logs view displayed a live list of intercepted HTTP requests, including update checks, image/script downloads, and service calls made by applications on the host.
- Individual log entries were inspected to reveal full request/response details, including headers and body content.
- Reviewing a POST request to `/service/update2/json` revealed a large JSON payload containing application/update metadata (OS, updater channel, app IDs, version data) sent in cleartext, alongside plaintext credential data captured elsewhere in the session logs.

5.3 Evidence



The screenshot shows the Hetty Proxy Logs dashboard at <http://localhost:8080/proxy/logs/>. The interface includes a search bar, a sidebar with navigation icons, and a table of intercepted HTTP requests. The table has columns for Method, Origin, Path, and Status. The requests are listed in chronological order, showing various GET and POST requests to different origins, including update.googleapis.com and www.moviescope.com. All requests shown have a status of 200 OK.

Method	Origin	Path	Status
POST	http://update.googleapis.com	/service/update2/json	200 OK
GET	http://edgedl.me.gvt1.c...	/edgedl/release2/chrome_component/af5e7gndpipvjfc...	200 OK
HEAD	http://edgedl.me.gvt1.c...	/edgedl/release2/chrome_component/af5e7gndpipvjfc...	200 OK
POST	http://update.googleapis.com	/service/update2/json	200 OK
GET	http://www.moviescope.com	/images/favicon.ico	200 OK
GET	http://www.moviescope.com	/images/bg_black_75.png	200 OK
GET	http://www.moviescope.com	/images/bg_main_menu.png	200 OK
GET	http://www.moviescope.com	/images/content/bg_body_1.jpg	200 OK
GET	http://www.moviescope.com	/js/jquery.script.js	200 OK
GET	http://www.moviescope.com	/js/jquery.superfish.js	200 OK
GET	http://www.moviescope.com	/js/jquery.min.js	200 OK
GET	http://www.moviescope.com	/js/jquery.flexslider-min.js	200 OK
GET	http://www.moviescope.com	/js/jquery.quicksand.js	200 OK

Figure 3: Hetty Proxy Logs dashboard, accessed at <http://localhost:8080/proxy/logs/>, showing intercepted HTTP requests from the Windows Server 2022 host.

The screenshot shows the Hetty Proxy logs interface (v0.7.0). The main view displays a POST request to `/service/update2/json` with a status of 200 OK. The request body is a JSON object containing various fields like `@os`, `@updater`, `acceptformat`, `apps`, `appid`, `brand`, `cohort`, `cohorthint`, `cohortname`, `enabled`, `events`, `download_time_ms`, `downloaded`, `downloader`, `bits`, `eventresult`, `eventtype`, `nextversion`, `pipeline_id`, `previousversion`, `total`, `url`, and `diffgen-puffin`. The response body is a JSON object containing fields like `Cache-Control`, `Content-Length`, `Content-Security-Policy`, `Content-Type`, `Date`, `Expires`, `Pragma`, `Server`, and `X-Content-Type-Options`.

Figure 4: Hetty — Detailed view of an intercepted POST request/response pair, showing full request body, headers, and status code (200 OK).

5.4 Key Findings

Answer (Task 2): The URL entered in the browser's address bar to open the Hetty dashboard was `http://localhost:8080`.

Answer (Task 3): The plaintext password captured by intercepting the Windows Server 2022 traffic in Hetty was test.

6. Task 4 — ARP-based Session Hijacking Detection with Bettercap and Wireshark

6.1 Objective

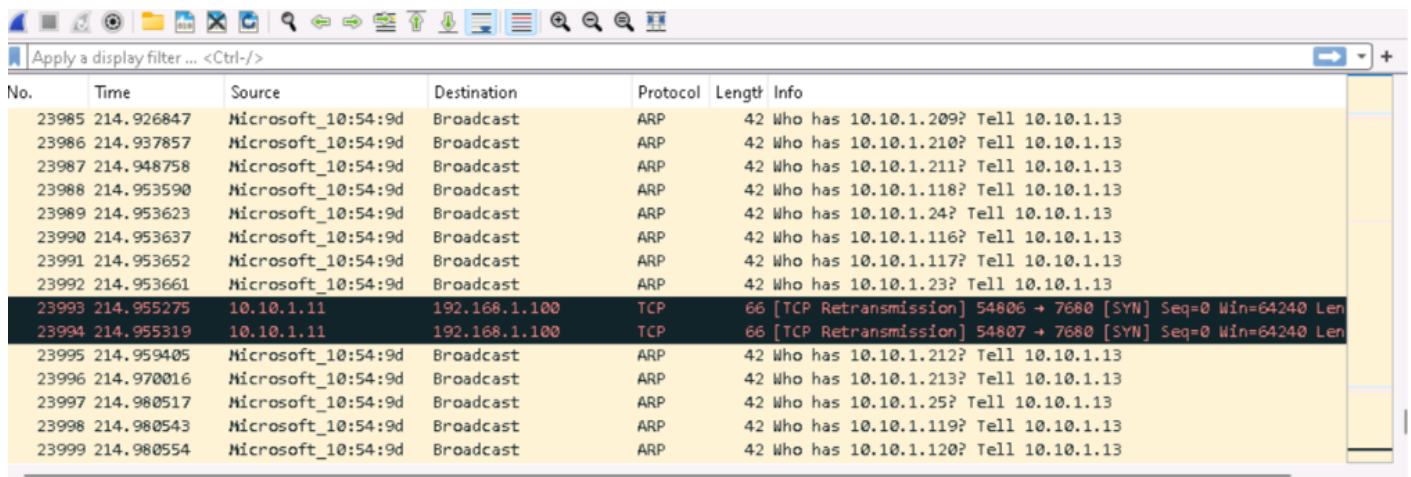
Use the Bettercap tool on the Parrot Security machine to sniff traffic on the target system (10.10.1.11), and use Wireshark on the target system to detect the resulting session hijacking attempt.

6.2 Procedure

- Bettercap was launched on the Parrot Security (attacker) machine using the `eth0` interface: `bettercap -iface eth0`.

- The built-in net.probe module was enabled, which in turn triggered net.recon to actively discover live hosts on the local subnet (10.10.1.0/24).
- Bettercap probed the subnet and enumerated endpoints, identifying hosts including 10.10.1.3, 10.10.1.11, and 10.10.1.22 (SERVER2022), along with their MAC addresses.
- On the target system (10.10.1.11), Wireshark was used to capture live traffic while the reconnaissance/spoofing activity was in progress.
- The Wireshark capture showed a high volume of broadcast ARP 'Who has ...? Tell 10.10.1.13' requests, consistent with ARP-based host discovery/spoofing behavior associated with a session hijacking (man-in-the-middle) attempt, alongside anomalous TCP SYN retransmissions.

6.3 Evidence



No.	Time	Source	Destination	Protocol	Length	Info
23985	214.926847	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.209? Tell 10.10.1.13
23986	214.937857	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.210? Tell 10.10.1.13
23987	214.948758	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.211? Tell 10.10.1.13
23988	214.953590	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.118? Tell 10.10.1.13
23989	214.953623	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.24? Tell 10.10.1.13
23990	214.953637	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.116? Tell 10.10.1.13
23991	214.953652	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.117? Tell 10.10.1.13
23992	214.953661	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.23? Tell 10.10.1.13
23993	214.955275	10.10.1.11	192.168.1.100	TCP	66	[TCP Retransmission] 54806 → 7680 [SYN] Seq=0 Win=64240 Len=0
23994	214.955319	10.10.1.11	192.168.1.100	TCP	66	[TCP Retransmission] 54807 → 7680 [SYN] Seq=0 Win=64240 Len=0
23995	214.959405	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.212? Tell 10.10.1.13
23996	214.970016	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.213? Tell 10.10.1.13
23997	214.980517	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.25? Tell 10.10.1.13
23998	214.980543	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.119? Tell 10.10.1.13
23999	214.980554	Microsoft_10:54:9d	Broadcast	ARP	42	Who has 10.10.1.120? Tell 10.10.1.13

Figure 5: Wireshark capture on the target system (10.10.1.11) showing a flood of ARP broadcast requests interleaved with TCP SYN retransmissions.

```
[root@parrot]~[/home/attacker]
#bettercap -iface eth0
bettercap v2.32.0 (built for linux amd64 with go1.19.8) [type 'help' for a list of commands]

10.10.1.0/24 > 10.10.1.13 » [15:53:01] [sys.log] [inf] gateway monitor started ...
10.10.1.0/24 > 10.10.1.13 » net.probe on
10.10.1.0/24 > 10.10.1.13 » [15:53:44] [sys.log] [inf] net.probe starting net.recon as a requirement for net.probe
10.10.1.0/24 > 10.10.1.13 » [15:53:44] [sys.log] [inf] net.probe probing 256 addresses on 10.10.1.0/24
10.10.1.0/24 > 10.10.1.13 » [15:53:44] [endpoint.new] endpoint 10.10.1.3 detected as 00:15:5d:10:54:9b (Microsoft Corporation).
10.10.1.0/24 > 10.10.1.13 » [15:53:44] [endpoint.new] endpoint fe80::5dbe:47b5:92ea:2691 detected as 00:15:5d:10:54:9f (Microsoft Corporation).
10.10.1.0/24 > 10.10.1.13 » [15:53:44] [endpoint.new] endpoint 10.10.1.11 detected as 00:15:5d:01:80:11 (Microsoft Corporation).
10.10.1.0/24 > 10.10.1.13 » [15:53:44] [endpoint.new] endpoint 10.10.1.22 (SERVER2022) detected as 00:15:5d:01:80:02 (Microsoft Corporation).
10.10.1.0/24 > 10.10.1.13 » net.recon on
```

Figure 6: Bettercap on the Parrot Security attacker machine — `net.probe/net.recon` actively enumerating hosts on the 10.10.1.0/24 subnet.

6.4 Key Finding

Answer: The traffic that indicates the session hijacking attempt in Wireshark is **ARP** (Address Resolution Protocol) traffic.

7. Summary of Findings

#	Task Description	Result / Answer	Status
1	Session hijack via proxy interception (Caido) on Firefox, redirecting a live moviescope.com session to goodshopping.com	Responses tab (Proxy → Intercept)	PASS
2	Hetty intercepting proxy dashboard access URL on Windows Server 2022	http://localhost:8080	PASS
3	Credential captured in plaintext via Hetty proxy interception on Windows Server 2022	test	PASS
4	Protocol identified in Wireshark indicating a session hijacking / MITM attempt (Bettercap ARP spoofing) on 10.10.1.11	ARP	PASS

The lab exercise was completed with a final assessed score of 4 out of 4, as confirmed by the module completion summary (Figure 7).

Module 11: Session Hijacking
CEHV13
Duration: 1 hour, 11 minutes

Print/Export

4/4
Congratulations, you passed!

- ☒ Use Caido tool on the attacker machine (10.10.1.11) to hijack a session established when a user on the victim machine (10.10.1.19) visits the website www.moviescope.com and redirect to www.goodshopping.com using the Firefox browser. Under which section does the Responses tab is located. Score: 1
- ☒ Use the Hetty tool to intercept HTTP traffic on the Windows Server 2022 machine. Enter the url that was entered in the address bar of the browser to open Hetty dashboard. Score: 1
- ☒ Use the Hetty tool to intercept HTTP traffic on the Windows Server 2022 machine. What was the password that was captured in Hetty tool by intercepting traffic of Windows Server 2022? Score: 1
- ☒ Use the bettercap tool (available in the Parrot Security machine) to sniff the traffic on the target system (10.10.1.11). Use the Wireshark tool on the target system (10.10.1.11) to detect the session hijacking attempt. Traffic on which protocol indicates the session hijacking attempt in Wireshark? Score: 1

Figure 7: Module 11 — Session Hijacking assessment summary showing all four tasks completed correctly (Score: 4/4, 'Congratulations, you passed!').

8. Conclusion

This lab demonstrated two distinct classes of session hijacking techniques: application-layer interception using HTTP proxy tools (Caido and Hetty), and network-layer hijacking via ARP spoofing/reconnaissance (Bettercap), detected through packet analysis in Wireshark. The exercise highlighted how unencrypted or improperly secured

sessions can be intercepted, modified, and redirected by an attacker positioned between the client and server, and how credentials transmitted without adequate protection can be trivially captured. It further reinforced the importance of network-level monitoring — such as ARP inspection and anomaly detection — as a defensive control against man-in-the-middle and session hijacking attacks.

8.1 Recommended Countermeasures

- Enforce HTTPS/TLS for all web sessions to prevent cleartext interception of session tokens and credentials.
- Implement Dynamic ARP Inspection (DAI) and Dynamic Host Configuration Protocol (DHCP) snooping on network switches to mitigate ARP spoofing.
- Use session tokens with short expiry, secure/HttpOnly cookie flags, and token binding to reduce the impact of a hijacked session.
- Deploy network intrusion detection systems (NIDS) to alert on abnormal ARP broadcast volumes and TCP anomalies.
- Educate users on the risks of untrusted networks and enforce use of VPNs on public or shared network segments.